

TJSC 2026 - Analista de Sistemas

Infraestrutura de TI e Computação em Nuvem

Aula 5

Firewall, proxy, VPN, DMZ, IDS, IPS e segurança em rede

Campo	Descrição
Disciplina	Infraestrutura de TI e Computação em Nuvem
Cargo	Analista de Sistemas - TJSC 2026
Banca	FGV - Fundação Getulio Vargas
Trilha	Aula 5 de 13
Foco	Segurança em rede: filtragem, intermediação, tunelamento, zonas, detecção e prevenção
Pré-requisitos	Aulas 1 a 4: OSI/TCP-IP, IP/DNS/DHCP/NAT, Ethernet/MAC/ARP/VLAN, TCP/UDP/HTTP/HTTPS/TLS

Como estudar: leia a teoria com atenção especial às diferenças finas. Em seguida, resolva as 20 questões sem olhar o gabarito. Depois leia o gabarito resumido e somente então os comentários. O objetivo desta aula não é decorar produtos de mercado, mas reconhecer função, camada, posição na arquitetura e limitação de cada mecanismo de segurança em rede.

1. Recorte da aula no edital e na trilha

Esta aula cobre a Aula 5 da trilha de Infraestrutura de TI e Computação em Nuvem: firewall, proxy, VPN - Virtual Private Network, DMZ - Demilitarized Zone, IDS - Intrusion Detection System, IPS - Intrusion Prevention System e segurança em rede.

No edital, o conteúdo está conectado ao item de redes de computadores, modelo OSI - Open Systems Interconnection - e protocolo TCP/IP - Transmission Control Protocol/Internet Protocol. Também dialoga com computação em nuvem e infraestrutura, porque firewalls, proxies, VPNs, DMZs e mecanismos IDS/IPS aparecem em ambientes físicos, virtualizados e cloud. A disciplina tem 8 questões, então o ROI está em distinguir conceitos próximos: filtrar, intermediar, criptografar, isolar, detectar e prevenir.

A ideia central: segurança em rede é uma arquitetura de controles complementares. Firewall não é proxy; proxy não é VPN; VPN não é autorização; DMZ não é uma rede sem proteção; IDS não bloqueia por padrão; IPS pode bloquear porque fica no caminho do tráfego.

Item da trilha	O que será coberto	Como pode cair na FGV
Firewall	Regras, filtragem, stateful/stateless, camadas L3/L4/L7, WAF e NGFW	Cenário com regra, tráfego, porta, política padrão, inspeção de estado ou aplicação
Proxy	Proxy direto, reverso, cache, autenticação, inspeção e relação com API Gateway	Distinguir proxy reverso, balanceador, NAT e firewall
VPN	Túnel seguro, site-to-site, client-to-site, IPsec, SSL/TLS VPN e limitações	Dizer o que a VPN protege e o que ela não substitui
DMZ	Zona desmilitarizada, segmentação de perímetro e proteção de serviços públicos	Escolher onde colocar web, API, banco e firewall
IDS/IPS	Deteção, prevenção, NIDS, HIDS, assinaturas, anomalias e falsos positivos	Separar monitoramento, alerta e bloqueio

2. Como a FGV costuma transformar esse assunto em questão

Em TI, a FGV tende a usar enunciados com situação concreta: órgão público, rede corporativa, aplicação web, serviço exposto à Internet, VPN para teletrabalho, política de firewall, alerta de IDS ou arquitetura com DMZ. A alternativa correta geralmente não é a definição mais bonita, mas a que preserva a função exata do mecanismo no cenário.

O padrão que vamos simular nas questões é: alternativas próximas, termos verdadeiros em contexto errado e mistura de camadas. Por exemplo: dizer que o firewall criptografa, que o proxy substitui autenticação, que a VPN elimina necessidade de autorização, que IDS bloqueia tráfego por padrão, ou que DMZ é uma rede interna comum.

Regra de prova: quando o enunciado descrever 'controlar tráfego por regra', pense em firewall. Quando falar em 'intermediar requisições', pense em proxy. Quando falar em 'túnel seguro sobre rede não confiável', pense em VPN. Quando falar em 'zona intermediária para serviços expostos', pense em DMZ. Quando falar em 'detectar e alertar', pense em IDS. Quando falar em 'bloquear inline', pense em IPS.

3. Siglas e termos essenciais

Sigla/termo	Expansão	Função mental para prova
ACL	Access Control List	Lista de regras que permite ou nega tráfego conforme critérios como IP, porta e protocolo.
DMZ	Demilitarized Zone	Zona intermediária para serviços expostos, isolando-os da rede interna sensível.
IDS	Intrusion Detection System	Sistema de detecção de intrusão: monitora e alerta.

Sigla/termo	Expansão	Função mental para prova
IPS	Intrusion Prevention System	Sistema de prevenção de intrusão: fica inline e pode bloquear.
NIDS	Network-based Intrusion Detection System	IDS baseado em rede, observando tráfego em segmento ou ponto de rede.
HIDS	Host-based Intrusion Detection System	IDS baseado em host, observando eventos, arquivos, logs e comportamento local.
VPN	Virtual Private Network	Rede privada virtual: túnel seguro sobre rede pública ou não confiável.
IPsec	Internet Protocol Security	Conjunto de protocolos para segurança na camada de rede, muito associado a VPN site-to-site.
SSL/TLS VPN	Secure Sockets Layer/Transport Layer Security VPN	VPN de acesso remoto baseada em TLS; o termo SSL permanece por tradição.
WAF	Web Application Firewall	Firewall de aplicação web, focado em HTTP/HTTPS e ataques como SQL injection e XSS.
NGFW	Next-Generation Firewall	Firewall de próxima geração: agrega inspeção mais profunda, identidade, aplicação e, às vezes, IPS.
NAT	Network Address Translation	Tradução de endereços; não é criptografia nem controle de acesso por si só.
DPI	Deep Packet Inspection	Inspeção profunda do conteúdo/payload ou metadados além do cabeçalho básico.
SIEM	Security Information and Event Management	Agrega, correlaciona e analisa eventos e logs de segurança.

4. Segurança em rede: o que cada controle tenta resolver

Segurança em rede começa com uma pergunta simples: que tráfego deve poder atravessar cada fronteira? A fronteira pode ser entre Internet e rede corporativa, entre VLANs internas, entre usuário remoto e datacenter, entre uma aplicação em DMZ e um banco de dados interno, ou entre workloads em nuvem.

A FGV pode cobrar isso por papéis. Um controle de filtragem decide permitir ou negar tráfego. Um controle de intermediação recebe uma requisição e a refaz em nome de alguém. Um controle de tunelamento cria comunicação protegida sobre uma rede não confiável. Um controle de segmentação separa zonas com níveis diferentes de exposição. Um controle de detecção monitora eventos suspeitos. Um controle de prevenção interfere no fluxo para impedir a ação.

Verbo do enunciado	Mecanismo provável	Cuidado
Permitir, negar, filtrar	Firewall, ACL, security group	Pode atuar em L3/L4 ou L7, dependendo do tipo.
Intermediar, representar cliente/servidor, cachear	Proxy	Proxy não é sinônimo de criptografia.
Tunelar, criptografar caminho, acesso remoto	VPN	VPN não autoriza automaticamente o usuário a tudo.
Isolar serviço exposto	DMZ	DMZ não deve conter tudo que é sensível.
Detectar, alertar	IDS	IDS não bloqueia por padrão.
Bloquear, descartar, impedir inline	IPS	IPS mal calibrado pode bloquear tráfego legítimo.

5. Firewall

5.1 Conceito básico

Firewall é um dispositivo, software ou serviço que controla o fluxo de tráfego entre redes, hosts ou zonas com posturas de segurança diferentes. Ele aplica uma política: o que pode entrar, o que pode sair, de onde, para onde, por qual protocolo, porta, estado ou aplicação.

Na prova, a palavra-chave é controle de tráfego. Um firewall pode permitir, negar, registrar e, em tecnologias mais avançadas, inspecionar estado, aplicação ou conteúdo. Mas não confunda: firewall não é, por definição, criptografia, autenticação de usuário final, antivírus, VPN ou IDS. Alguns produtos combinam funções, mas a questão normalmente cobra a função descrita.

Critério de regra	Exemplo	Camada associada
Endereço IP de origem/destino	Permitir 10.0.1.0/24 -> 172.16.10.20	Rede / Internet
Porta TCP/UDP	Permitir TCP/443 para servidor web	Transporte
Protocolo	Permitir ICMP apenas de rede de monitoramento	Rede/transporte, conforme protocolo
Estado da conexão	Permitir resposta de conexão já estabelecida	Firewall stateful
Aplicação/URL/método	Bloquear POST suspeito para /login	Aplicação / WAF / NGFW

5.2 Política padrão: default deny e menor privilégio

Uma política madura costuma partir de default deny: negar por padrão e permitir apenas o tráfego necessário. Em prova, essa ideia aparece como princípio do menor privilégio aplicado à rede. Uma regra 'allow any any' é funcionalmente cômoda, mas insegura; ela contraria a segmentação e abre superfície de ataque.

A ordem das regras também pode importar: em muitos firewalls, a primeira regra correspondente é aplicada. Portanto, uma regra permissiva ampla antes de uma regra restritiva específica pode neutralizar a proteção esperada.

Exemplo: se a regra 1 permite qualquer origem para qualquer destino na porta TCP/443, uma regra 2 que tenta negar acesso de uma origem maliciosa à mesma porta pode nunca ser avaliada, dependendo do produto e da política de processamento.

5.3 Firewall stateless x stateful

Firewall stateless, ou sem estado, avalia pacotes de forma individual. Ele olha critérios como origem, destino, porta e protocolo, mas não mantém memória completa do contexto da conexão. Já o firewall stateful, ou com estado, mantém tabela de conexões e entende, por exemplo, que um pacote de resposta faz parte de uma comunicação iniciada legitimamente de dentro para fora.

Aspecto	Stateless	Stateful
Memória de conexão	Não acompanha contexto completo	Mantém tabela de estado
Decisão típica	Pacote a pacote	Pacote + contexto da sessão/conexão
Exemplo de regra	Permitir TCP/443 de A para B	Permitir retorno de conexão estabelecida
Risco de prova	Achar que ele sabe se tráfego é resposta legítima	Achar que ele entende regra de negócio da aplicação

5.4 Firewall de pacote, firewall de aplicação, WAF e NGFW

Um firewall de filtragem de pacotes trabalha principalmente com cabeçalhos de rede e transporte. Um firewall de aplicação, em sentido amplo, consegue considerar elementos de protocolos de aplicação. Um WAF - Web Application Firewall - é especializado em tráfego web HTTP/HTTPS, buscando padrões de ataque contra aplicações, como SQL injection, Cross-Site Scripting e manipulação de parâmetros.

NGFW - Next-Generation Firewall - é um termo de mercado para firewalls que agregam inspeção mais profunda, reconhecimento de aplicações, identidade de usuário, reputação, integração com IPS e

outras capacidades. Para prova, cuidado: NGFW não significa proteção automática contra erro de código, má configuração, credenciais fracas ou ausência de autorização na API.

Tipo	Enxerga melhor	Limitação clássica
Filtro de pacotes	IP, porta, protocolo	Não entende profundamente HTTP, JSON ou regra de negócio
Stateful firewall	Estado da conexão	Não substitui validação de aplicação
WAF	Requisições HTTP/HTTPS, cabeçalhos, URI, parâmetros	Não protege tráfego não web como SSH ou banco diretamente
NGFW	Aplicação, usuário, conteúdo, reputação e estado, conforme produto	É categoria ampla; não é mágica nem substitui arquitetura segura

6. Proxy

6.1 Conceito

Proxy é um intermediário de comunicação. Em vez de o cliente falar diretamente com o servidor final, ou o cliente externo falar diretamente com o backend, a requisição passa por um servidor intermediário que pode controlar, registrar, autenticar, cachear, filtrar, mascarar ou encaminhar a comunicação.

O ponto central para prova é diferenciar proxy direto e proxy reverso. O proxy direto representa clientes internos perante a Internet. O proxy reverso representa servidores internos perante clientes externos. Essa distinção derruba muita questão porque os dois são 'proxy', mas ficam em lados opostos da arquitetura.

Tipo de proxy	Quem ele representa	Fluxo mental	Uso comum
Proxy direto / forward proxy	Clientes internos	Cliente -> proxy -> Internet	Controle de navegação, cache, autenticação, política corporativa
Proxy reverso / reverse proxy	Servidores internos	Internet -> proxy reverso -> servidores	Publicação de aplicações, TLS termination, load balancing, cache, proteção de backend

6.2 Proxy reverso, API Gateway e balanceador

No seu mundo de dev/API, o proxy reverso é muito próximo da infraestrutura que fica na frente de serviços web. Ele pode receber chamadas HTTPS externas, encerrar TLS, aplicar regras, inserir cabeçalhos, fazer roteamento para /api, /auth ou /static, e encaminhar a requisição a uma aplicação Java/Quarkus interna.

API Gateway é um padrão/componente de camada de aplicação que pode acumular papéis de proxy reverso, roteamento, autenticação, limitação de taxa, transformação de requisições e controle de APIs. Um balanceador distribui tráfego entre instâncias; se opera em L4, decide por IP/porta/conexão; se opera em L7, entende HTTP. A FGV pode tentar tratar todos como a mesma coisa. Não são idênticos, embora possam coexistir no mesmo produto.

Componente	Função dominante	Pegadinha
Proxy reverso	Intermediar requisições para servidores internos	Não é necessariamente firewall completo
API Gateway	Governar e expor APIs em camada de aplicação	Não é apenas roteador IP
Balanceador L4	Distribuir conexões por IP/porta	Não entende URI ou método HTTP
Balanceador L7	Distribuir por informação HTTP	Não substitui autenticação/ autorização da aplicação

Componente	Função dominante	Pegadinha
WAF	Inspecionar tráfego web contra padrões de ataque	Não é firewall genérico para qualquer protocolo

7. VPN - Virtual Private Network

7.1 Conceito básico

VPN - Virtual Private Network - cria um túnel lógico protegido sobre uma rede não confiável, como a Internet. O objetivo é permitir que tráfego entre pontos seja protegido por mecanismos como criptografia, autenticação de origem, integridade e proteção contra repetição, conforme a tecnologia usada.

Em prova, VPN não deve ser traduzida como 'acesso irrestrito'. Ela cria conectividade segura, mas não substitui autenticação forte, autorização, segmentação, firewall, logs, gestão de identidade nem controles de endpoint. Um usuário conectado por VPN ainda deve acessar apenas o que sua função permite.

7.2 Site-to-site x client-to-site

Tipo	Conecta	Exemplo	Cobrança provável
Site-to-site	Duas redes	Datacenter do órgão com nuvem ou filial	Túnel entre gateways; usuários nem sempre percebem a VPN
Client-to-site	Um dispositivo de usuário a uma rede	Servidor remoto, notebook em teletrabalho	Cliente VPN ou acesso via navegador, autenticação do usuário

7.3 IPsec VPN e SSL/TLS VPN

IPsec - Internet Protocol Security - fornece serviços de segurança na camada de rede. É muito associado a VPNs site-to-site e a cenários em que se deseja proteger tráfego IP entre redes ou hosts. SSL/TLS VPN é termo tradicional para VPNs de acesso remoto baseadas em TLS - Transport Layer Security -, muitas vezes acessíveis por navegador ou cliente leve.

Tecnologia	Camada mental	Uso comum	Cuidado
IPsec	Rede / IP	Túneis site-to-site, host-to-gateway	Não confundir com HTTPS; protege tráfego IP conforme configuração
SSL/TLS VPN	Aplicação/transporte seguro, conforme implementação	Acesso remoto a aplicações internas	O termo SSL é histórico; o padrão moderno é TLS
HTTPS	HTTP sobre TLS	Acesso seguro a sites e APIs	Não é por si só uma VPN

8. DMZ - Demilitarized Zone

8.1 Conceito

DMZ - Demilitarized Zone - é uma rede ou zona intermediária usada para hospedar serviços que precisam ser acessíveis de fora, mas que não devem ficar diretamente dentro da rede interna sensível. A DMZ reduz o impacto de uma eventual invasão ao serviço exposto, porque o atacante não ganha automaticamente acesso à rede interna.

Pense em uma aplicação web pública: usuários da Internet acessam o front ou o proxy reverso na DMZ. A aplicação, quando necessário, acessa serviços internos por regras específicas. O banco de dados, em geral, deve ficar em rede interna protegida, não na DMZ, salvo arquitetura especial muito bem justificada.

Zona	Exposição	Exemplo	Regra mental
Internet	Não confiável	Usuários externos, atacantes, provedores	Nunca confiar por origem externa
DMZ	Exposta e controlada	Proxy reverso, WAF, web server, VPN gateway	Serviços públicos ficam aqui, com regras restritivas
Rede interna	Sensível	Banco, sistemas internos, AD/LDAP, serviços administrativos	Acesso direto da Internet deve ser evitado

8.2 DMZ com um firewall ou dois firewalls

Há desenhos diferentes. Em uma arquitetura de três interfaces, um firewall possui interface para Internet, uma para DMZ e uma para rede interna. Em uma arquitetura com dois firewalls, um separa Internet-DMZ e outro separa DMZ-rede interna. A FGV não deve exigir desenho de fabricante, mas pode perguntar a finalidade: segmentar e limitar o caminho entre ambiente externo, serviços expostos e rede interna.

Diagrama textual: Internet -> Firewall externo -> DMZ com proxy/WAF/web -> Firewall interno -> rede interna com banco e serviços corporativos. O importante é que o comprometimento do web server na DMZ não deve dar caminho livre para o banco interno.

9. IDS e IPS

9.1 IDS - detecção

IDS - Intrusion Detection System - monitora eventos ou tráfego para identificar atividades suspeitas ou maliciosas. O foco é detectar e alertar. Um IDS pode estar posicionado na rede, como NIDS - Network-based Intrusion Detection System -, ou em hosts, como HIDS - Host-based Intrusion Detection System.

O IDS pode usar assinaturas, procurando padrões conhecidos de ataque, ou análise de anomalias, procurando desvios em relação ao comportamento esperado. Assinaturas tendem a ser boas para ameaças conhecidas; anomalias podem detectar comportamentos novos, mas costumam exigir mais calibração e podem gerar mais falsos positivos.

9.2 IPS - prevenção

IPS - Intrusion Prevention System - vai além de detectar: ele fica inline, no caminho do tráfego, e pode bloquear, descartar, resetar conexão ou aplicar outra ação de contenção. O benefício é reação imediata; o risco é indisponibilidade por falso positivo, quando o sistema interpreta tráfego legítimo como malicioso.

Aspecto	IDS	IPS
Posição típica	Fora do caminho direto ou espelhado, embora haja variações	Inline, no caminho do tráfego
Ação principal	Detectar e alertar	Detectar e bloquear/prevenir
Risco típico	Não impedir a ação a tempo	Bloquear tráfego legítimo
Verbo de prova	Monitorar, alertar, registrar	Bloquear, descartar, resetar, prevenir

9.3 NIDS, HIDS, assinaturas e anomalias

Classificação	O que observa	Exemplo de uso	Limitação
NIDS	Tráfego de rede	Sensor em segmento de rede ou espelhamento	Pode perder visibilidade com tráfego cifrado
HIDS	Eventos do host	Logs, arquivos, integridade, processos	Não vê toda a rede

Classificação	O que observa	Exemplo de uso	Limitação
Assinaturas	Padrões conhecidos	Regra para payload de ataque conhecido	Não detecta bem variação inédita
Anomalias	Desvio do comportamento normal	Volume incomum, conexão fora do padrão	Pode gerar falso positivo se mal calibrado

9.4 Falso positivo e falso negativo

Falso positivo ocorre quando o sistema alerta ou bloqueia algo legítimo como se fosse ameaça. Em IDS, isso gera ruído operacional; em IPS, pode causar indisponibilidade. Falso negativo ocorre quando uma ameaça real passa despercebida. A prova pode cobrar a diferença sem usar linguagem estatística: 'bloqueou tráfego legítimo' é falso positivo; 'não detectou ataque real' é falso negativo.

10. Exemplo prático: requisição web passando por perímetro seguro

Imagine um sistema web do TJSC com front-end acessado por navegador, API backend e banco interno. Um fluxo simplificado poderia ser:

Navegador do usuário -> DNS resolve o nome -> conexão TCP/443 -> handshake TLS -> WAF/proxy reverso na DMZ -> API interna em rede de aplicação -> firewall interno -> banco de dados em rede protegida -> resposta volta pelo caminho controlado.

Componente	Função no fluxo	O que não faz sozinho
DNS	Resolve nome para endereço IP	Não filtra ataque HTTP
Firewall de borda	Controla tráfego Internet-DMZ	Não entende toda regra de negócio da API
WAF	Inspeciona tráfego web	Não corrige código inseguro
Proxy reverso	Encaminha requisições para backend	Não substitui autorização da aplicação
DMZ	Isola serviço exposto	Não é local ideal para banco sensível
Firewall interno	Controla DMZ -> rede interna	Não é SIEM nem auditoria completa
IDS/IPS	Detecta ou previne atividade suspeita	Não substitui hardening, patching e IAM

11. Troubleshooting e leitura de sintomas

A FGV pode não perguntar 'o que é firewall?'. Ela pode dar um sintoma e pedir o componente mais provável. Esse tipo de raciocínio é útil para prova e para trabalho.

Sintoma	Hipótese forte	Raciocínio
Timeout ao acessar porta TCP/443 externa	Firewall, rota, NAT ou serviço fora	O pacote pode não chegar ou a resposta pode não voltar.
HTTP 403 vindo de WAF/proxy	Bloqueio em camada de aplicação	A rede funciona, mas política de aplicação negou.
Erro de certificado TLS	Problema de certificado, cadeia, nome ou terminação TLS	Não é necessariamente firewall.
Usuário conecta na VPN, mas não acessa sistema	Autorização, rota, firewall interno ou DNS	VPN cria túnel; não garante acesso a tudo.
IDS gera muitos alertas de tráfego legítimo	Falso positivo ou regra mal calibrada	Deteção sensível demais causa ruído.
IPS derruba acesso válido	Falso positivo com bloqueio inline	Risco operacional do modo prevenção.

12. Pegadinhas FGV

Pegadinha	Correção
Firewall criptografa comunicação por definição.	Errado. Firewall filtra/controla tráfego. Criptografia é função de TLS, IPsec, VPN ou protocolos correlatos.
Proxy reverso representa clientes internos.	Errado. Proxy reverso representa servidores internos para clientes externos. Quem representa clientes é proxy direto.
VPN elimina necessidade de autenticação e autorização.	Errado. VPN cria túnel seguro; acesso deve continuar restrito por identidade, autorização e regras de rede.
DMZ é parte da rede interna sem controles.	Errado. DMZ é zona intermediária exposta e controlada, criada para limitar impacto de comprometimento.
IDS bloqueia tráfego automaticamente.	Errado como regra. IDS detecta e alerta; IPS pode bloquear por estar inline.
WAF protege qualquer protocolo de rede.	Errado. WAF é focado em aplicações web e tráfego HTTP/HTTPS.
NAT é uma técnica de segurança equivalente a firewall.	Errado. NAT traduz endereços; pode ocultar topologia, mas não substitui política de filtragem.
IPS sempre é melhor que IDS.	Não necessariamente. IPS reage, mas falso positivo pode causar indisponibilidade.

13. Mapa mental textual

SEGURANÇA EM REDE

- | - Firewall: filtra/controla tráfego por regras
- | | - Stateless: pacote a pacote
- | | - Stateful: acompanha estado da conexão
- | | - WAF: aplicação web HTTP/HTTPS
- | | - NGFW: inspeção mais profunda e recursos integrados
- | - Proxy: intermediário
- | | - Forward proxy: representa clientes
- | | - Reverse proxy: representa servidores
- | - VPN: túnel seguro
- | | - Site-to-site: rede com rede
- | | - Client-to-site: usuário com rede
- | | - IPsec: segurança em camada de rede
- | | - SSL/TLS VPN: acesso remoto via TLS
- | - DMZ: zona intermediária para serviços expostos
- | - IDS: detecta e alerta
- | | - NIDS: rede
- | | - HIDS: host
- | - IPS: previne/bloqueia inline
- | - Operação: logs, revisão de regras, menor privilégio, segmentação e correlação

14. Questões autorais - padrão FGV

Instruções: resolva as 20 questões sem consultar o gabarito. As questões misturam conceitos diretos, cenário prático, afirmativas, V/F, relacionamento de conceitos e interpretação de arquitetura. Há apenas uma alternativa correta por questão.

Questão 1

Em uma rede corporativa, a equipe de infraestrutura deseja controlar quais fluxos podem atravessar a fronteira entre a Internet e uma zona de servidores expostos. O mecanismo cuja função típica é permitir ou negar tráfego com base em critérios como origem, destino, protocolo, porta e, em alguns casos, estado da conexão, é o:

- (A) proxy reverso, pois sua função essencial é criar túneis cifrados entre redes.
- (B) IDS, pois sua função essencial é descartar pacotes suspeitos antes que alcancem o destino.
- (C) firewall, pois sua função essencial é aplicar política de controle de tráfego entre redes ou zonas.
- (D) DNS, pois sua função essencial é associar tráfego de rede a regras de autorização.
- (E) DHCP, pois sua função essencial é bloquear endereços IP externos não autorizados.

Questão 2

Um analista observa que determinado equipamento permite automaticamente o tráfego de resposta de uma conexão TCP iniciada de dentro da rede, sem exigir uma regra explícita para cada pacote de retorno, pois mantém uma tabela de conexões estabelecidas. Esse comportamento é mais bem associado a um firewall:

- (A) de camada física, pois ele identifica o cabo por onde a conexão foi iniciada.
- (B) sem estado, pois ele avalia cada pacote isoladamente sem guardar contexto.
- (C) WAF, pois ele sempre classifica conexões TCP por assinatura de ataque web.
- (D) stateful, pois ele considera o estado da comunicação ao tomar a decisão.
- (E) de tradução de endereços, pois NAT sempre equivale a controle de estado.

Questão 3

Em uma política de segurança de rede, a organização adota a premissa de negar todo tráfego não autorizado explicitamente, liberando apenas os fluxos necessários ao negócio. Essa estratégia é conhecida, em linguagem de segurança, como:

- (A) permit any any, por simplificar a administração de regras.
- (B) default deny, alinhada ao princípio do menor privilégio.
- (C) fail open, pois a conectividade deve prevalecer em caso de dúvida.
- (D) full mesh, pois todos os segmentos devem se comunicar entre si.
- (E) proxy transparente, pois todo tráfego passa sem autenticação.

Questão 4

Uma aplicação pública apresenta tentativas recorrentes de SQL injection e Cross-Site Scripting em endpoints HTTP. Sem substituir a correção do código, o controle de perímetro mais especializado para inspecionar requisições web e aplicar regras contra esse tipo de ataque é:

- (A) NAT, por traduzir endereços privados para públicos.
- (B) hub, por repetir o tráfego web para todos os servidores.
- (C) VPN, por cifrar automaticamente todo formulário enviado pela aplicação.
- (D) DHCP snooping, por distribuir endereços válidos aos clientes HTTP.
- (E) WAF - Web Application Firewall.

Questão 5

Em uma arquitetura de publicação de serviços, servidores acessíveis pela Internet são colocados em uma zona intermediária, separada tanto da Internet quanto da rede interna onde estão bases de dados

e sistemas sensíveis. Essa zona é denominada:

- (A) DMZ - Demilitarized Zone.
- (B) HIDS - Host-based Intrusion Detection System.
- (C) SAN - Storage Area Network.
- (D) CIDR - Classless Inter-Domain Routing.
- (E) VLAN nativa de gerenciamento.

Questão 6

No desenho de uma aplicação web, um componente fica à frente de vários servidores internos, recebe requisições HTTPS de clientes externos, pode encerrar TLS e encaminha as requisições aos backends apropriados. Esse componente atua, predominantemente, como:

- (A) proxy direto, pois representa clientes internos em navegação para a Internet.
- (B) roteador de camada 3, pois decide exclusivamente com base em prefixo IP.
- (C) proxy reverso, pois representa servidores internos perante clientes externos.
- (D) servidor DHCP, pois entrega endereços aos backends web.
- (E) NIDS, pois todo proxy reverso bloqueia intrusões por padrão.

Questão 7

A respeito de proxy direto e proxy reverso, assinale a afirmativa correta.

- (A) O proxy direto representa servidores internos, enquanto o reverso representa clientes internos.
- (B) Ambos substituem integralmente firewall, autenticação e autorização da aplicação.
- (C) O proxy reverso é usado apenas para tráfego UDP e não pode operar com HTTP.
- (D) O proxy direto é necessariamente uma VPN, pois estabelece túnel criptografado.
- (E) O proxy direto normalmente intermedeia saídas de clientes; o reverso intermedeia entradas para servidores.

Questão 8

Um órgão pretende interligar, por meio da Internet, a rede de sua sede e a rede de um datacenter contratado, de modo que os segmentos se comuniquem por um túnel protegido entre gateways. O tipo de VPN mais adequado a essa descrição é:

- (A) client-to-site, pois cada usuário final deve iniciar manualmente a sessão a partir do navegador.
- (B) site-to-site, pois conecta redes por meio de gateways VPN.
- (C) host-only, pois impede qualquer comunicação entre redes.
- (D) forward proxy, pois representa servidores para os clientes externos.
- (E) WAF, pois protege automaticamente toda comunicação IP.

Questão 9

Considere as afirmativas sobre VPN - Virtual Private Network. I. Uma VPN pode proteger tráfego por meio de túnel cifrado sobre rede não confiável. II. A conexão VPN, por si só, torna desnecessárias regras de autorização e segmentação interna. III. Em acesso remoto, a VPN pode permitir que um dispositivo externo alcance recursos internos conforme políticas definidas. Está correto o que se afirma em:

- (A) I, II e III.
- (B) II, apenas.
- (C) I e II, apenas.
- (D) I e III, apenas.
- (E) III, apenas.

Questão 10

Um sensor de segurança recebe cópia do tráfego de um switch, analisa pacotes suspeitos e envia alertas para a equipe de segurança, mas não está no caminho obrigatório do tráfego e não bloqueia automaticamente a comunicação. Esse sensor exerce função típica de:

- (A) IDS, pois sua função principal é detectar e alertar.
- (B) IPS, pois todo sensor que analisa tráfego bloqueia pacotes por padrão.
- (C) firewall stateful, pois mantém tabela de conexões e aplica NAT.
- (D) proxy reverso, pois representa os servidores diante da Internet.
- (E) DMZ, pois toda zona intermediária é um dispositivo de monitoramento.

Questão 11

Em uma implantação, determinado equipamento é posicionado inline entre a Internet e a rede da organização. Ao identificar tráfego que corresponde a uma assinatura de exploração conhecida, ele descarta os pacotes antes que alcancem o servidor. Essa atuação é mais bem descrita como:

- (A) DNS recursivo com cache negativo.
- (B) IDS passivo, por apenas gerar alerta fora de banda.
- (C) IPS, por detectar e prevenir/bloquear tráfego no caminho.
- (D) proxy direto, por representar clientes internos.
- (E) VLAN, por separar domínios de broadcast.

Questão 12

Associe os mecanismos às descrições. 1. NIDS. 2. HIDS. 3. WAF. 4. VPN. () Observa tráfego em ponto de rede. () Observa eventos e integridade de um host. () Inspecciona requisições HTTP/HTTPS contra ataques de aplicação web. () Cria túnel protegido sobre rede não confiável. A sequência correta é:

- (A) 2, 1, 3, 4.
- (B) 1, 2, 3, 4.
- (C) 1, 3, 2, 4.
- (D) 3, 2, 4, 1.
- (E) 4, 1, 2, 3.

Questão 13

Um administrador configurou um IPS com regras muito agressivas. Após a mudança, usuários legítimos passaram a perder acesso a uma API interna porque o tráfego normal foi classificado como ataque e bloqueado. O caso descreve, principalmente:

- (A) falso negativo, pois uma ameaça real não foi detectada.
- (B) falha de DNS, pois a API não pode ter sido resolvida.
- (C) sucesso de NAT, pois a tradução impediu vazamento de IP.
- (D) roteamento assimétrico, que sempre indica ataque em camada 7.
- (E) falso positivo, com impacto maior por o mecanismo atuar em modo de prevenção.

Questão 14

Em relação a uma DMZ, assinale a opção correta.

- (A) Deve concentrar todos os bancos de dados críticos, pois é a zona mais confiável da rede.
- (B) Serve para dispensar firewall interno, já que a presença da DMZ torna a rede automaticamente segura.
- (C) É uma técnica de criptografia de pacotes equivalente ao IPsec.
- (D) É uma zona intermediária para serviços expostos, reduzindo o acesso direto da Internet à rede interna.
- (E) É um protocolo de camada de transporte usado para tunelamento de portas TCP.

Questão 15

Um proxy corporativo exige autenticação de usuários internos, registra acessos e aplica políticas de navegação para tráfego de saída para a Internet. Nesse caso, a classificação mais adequada é:

- (A) proxy reverso, pois ele representa servidores internos para clientes externos.
- (B) proxy direto, pois ele representa clientes internos perante destinos externos.
- (C) HIDS, pois ele monitora integridade de arquivos locais.
- (D) VPN site-to-site, pois conecta duas redes por túneis entre gateways.
- (E) WAF, pois toda política de navegação é regra de aplicação web pública.

Questão 16

Considere o trecho de política: 'Permitir TCP/443 da Internet apenas para o proxy reverso na DMZ; permitir do proxy reverso para a API interna apenas TCP/8443; negar qualquer acesso direto da Internet ao banco de dados'. A leitura mais adequada é que a política busca:

- (A) eliminar a necessidade de autenticação na aplicação, pois o proxy já autentica todo usuário externo.
- (B) permitir que a Internet acesse diretamente o banco, desde que usando HTTPS.
- (C) segmentar o tráfego em camadas, expondo apenas o necessário e protegendo a rede interna.
- (D) substituir TLS por NAT, já que a porta 443 indica criptografia no firewall.
- (E) transformar a DMZ em rede interna plena, sem controle adicional.

Questão 17

Sobre firewall, proxy, VPN, DMZ, IDS e IPS, analise as afirmativas a seguir. I. Firewall e proxy podem coexistir, mas têm funções distintas: filtragem/controle de tráfego e intermediação de requisições. II. IDS e IPS têm a mesma consequência operacional, pois ambos bloqueiam tráfego inline por definição. III. VPN cria túnel seguro, mas não substitui política de acesso, autorização e monitoramento. Está correto o que se afirma em:

- (A) I e III, apenas.
- (B) I, II e III.
- (C) II, apenas.
- (D) I e II, apenas.
- (E) III, apenas.

Questão 18

Em um ambiente com tráfego HTTPS, a equipe quer que um WAF inspecione parâmetros HTTP e cabeçalhos de aplicação antes de encaminhar requisições aos servidores. Para isso, em uma arquitetura comum, o componente de borda pode realizar:

- (A) apenas repetição elétrica de sinais, como um hub.
- (B) encapsulamento ARP de todos os parâmetros HTTP.
- (C) atribuição automática de IP aos clientes via DHCP.
- (D) desativação de qualquer certificado, pois WAF só funciona em texto claro inseguro.
- (E) terminação TLS ou integração equivalente que permita visibilidade do tráfego de aplicação, respeitadas as políticas de segurança.

Questão 19

A equipe de segurança detectou que um servidor web na DMZ foi comprometido. A arquitetura, porém, impediu que o atacante se conectasse diretamente ao banco de dados interno, pois o firewall interno permitia apenas fluxos específicos do servidor de aplicação. O controle que melhor explica a limitação do impacto é:

- (A) substituição de HTTP por UDP.
- (B) eliminação de logs para reduzir superfície de ataque.
- (C) uso de hub para isolar domínios de colisão.

- (D) segmentação por DMZ e regras restritivas entre zonas.
- (E) resolução reversa de DNS para impedir conexão TCP.

Questão 20

Assinale a alternativa que apresenta a relação tecnicamente mais adequada entre mecanismo e limitação.

- (A) VPN: protege o túnel e, por isso, dispensa controle de identidade e autorização.
- (B) Firewall L3/L4: filtra por IP, protocolo e porta, mas não compreende plenamente regras de negócio de uma API REST.
- (C) IDS: detecta intrusão e, por definição, sempre bloqueia os pacotes inline.
- (D) WAF: protege qualquer protocolo, inclusive ARP, ICMP e tráfego de armazenamento em bloco.
- (E) DMZ: transforma servidores expostos em ativos internos sem necessidade de segmentação.

15. Gabarito resumido

Questão	Gabarito	Questão	Gabarito	Questão	Gabarito	Questão	Gabarito
1	C	2	D	3	B	4	E
5	A	6	C	7	E	8	B
9	D	10	A	11	C	12	B
13	E	14	D	15	B	16	C
17	A	18	E	19	D	20	B

16. Comentários completos

Questão 1 - Gabarito: C

Por que a correta está correta: Firewall é o mecanismo típico de controle de fluxo entre redes ou zonas, avaliando critérios como origem, destino, protocolo, porta e estado, conforme o tipo.

Por que a alternativa A parece tentadora, mas está errada: proxy reverso intermedeia requisições para servidores internos; não tem como função essencial criar túnel cifrado.

Por que a alternativa B parece tentadora, mas está errada: IDS detecta e alerta; descartar antes do destino é comportamento de IPS, não de IDS típico.

Por que a alternativa D parece tentadora, mas está errada: DNS resolve nomes, não aplica política de tráfego.

Por que a alternativa E parece tentadora, mas está errada: DHCP atribui configuração IP aos clientes; não bloqueia tráfego externo por política.

Questão 2 - Gabarito: D

Por que a correta está correta: Firewall stateful mantém estado de conexões e, por isso, pode reconhecer tráfego de retorno relacionado a uma sessão iniciada legitimamente.

Por que a alternativa A parece tentadora, mas está errada: camada física trata sinais e meio, não estado TCP.

Por que a alternativa B parece tentadora, mas está errada: stateless é o oposto: avalia pacotes sem guardar contexto relevante.

Por que a alternativa C parece tentadora, mas está errada: WAF pode inspecionar HTTP, mas a pista do enunciado é tabela de estado de conexão TCP.

Por que a alternativa E parece tentadora, mas está errada: NAT pode coexistir com estado, mas tradução de endereço não é sinônimo de firewall stateful.

Questão 3 - Gabarito: B

Por que a correta está correta: Default deny é a política de negar por padrão e liberar apenas o que foi autorizado, alinhando-se ao menor privilégio.

Por que a alternativa A parece tentadora, mas está errada: permit any any é permissivo demais e inseguro.

Por que a alternativa C parece tentadora, mas está errada: fail open deixa passar em caso de falha; não é a estratégia descrita.

Por que a alternativa D parece tentadora, mas está errada: full mesh é topologia/conectividade, não política de negação por padrão.

Por que a alternativa E parece tentadora, mas está errada: proxy transparente é modo de intermediação; não equivale a default deny.

Questão 4 - Gabarito: E

Por que a correta está correta: WAF é o controle especializado para tráfego HTTP/HTTPS e ataques contra aplicação web, como SQL injection e XSS.

Por que a alternativa A parece tentadora, mas está errada: NAT traduz endereços; não inspeciona semântica HTTP contra SQL injection.

Por que a alternativa B parece tentadora, mas está errada: hub é dispositivo antigo de repetição, sem filtragem inteligente.

Por que a alternativa C parece tentadora, mas está errada: VPN pode proteger canal, mas não analisa payload de aplicação contra ataques web.

Por que a alternativa D parece tentadora, mas está errada: DHCP snooping protege contra problemas de DHCP em LAN, não contra ataque HTTP.

Questão 5 - Gabarito: A

Por que a correta está correta: DMZ é a zona intermediária usada para expor serviços de forma controlada e reduzir acesso direto à rede interna.

Por que a alternativa B parece tentadora, mas está errada: HIDS monitora host, não define zona de rede.

Por que a alternativa C parece tentadora, mas está errada: SAN é rede de armazenamento.

Por que a alternativa D parece tentadora, mas está errada: CIDR é técnica de endereçamento/roteamento sem classes.

Por que a alternativa E parece tentadora, mas está errada: VLAN nativa de gerenciamento não é, por si, zona desmilitarizada.

Questão 6 - Gabarito: C

Por que a correta está correta: Proxy reverso fica do lado dos servidores e representa serviços internos perante clientes externos.

Por que a alternativa A parece tentadora, mas está errada: proxy direto representa clientes internos em saídas para a Internet.

Por que a alternativa B parece tentadora, mas está errada: um roteador L3 decide por IP, não por HTTPS, TLS termination ou backend web.

Por que a alternativa D parece tentadora, mas está errada: DHCP atribui IP; não encaminha requisições HTTPS.

Por que a alternativa E parece tentadora, mas está errada: NIDS detecta tráfego; proxy reverso não bloqueia intrusão por definição.

Questão 7 - Gabarito: E

Por que a correta está correta: A distinção essencial é esta: forward proxy representa clientes; reverse proxy representa servidores.

Por que a alternativa A parece tentadora, mas está errada: inverte as funções.

Por que a alternativa B parece tentadora, mas está errada: proxy não substitui todos os controles de segurança.

Por que a alternativa C parece tentadora, mas está errada: proxy reverso é muito comum com HTTP/HTTPS, não apenas UDP.

Por que a alternativa D parece tentadora, mas está errada: proxy direto não é necessariamente túnel criptografado nem VPN.

Questão 8 - Gabarito: B

Por que a correta está correta: Site-to-site conecta redes por gateways VPN, formando túnel entre dois ambientes.

Por que a alternativa A parece tentadora, mas está errada: client-to-site é acesso de dispositivo/usuário a rede, não rede com rede.

Por que a alternativa C parece tentadora, mas está errada: host-only é termo comum de virtualização/rede local isolada, não VPN de datacenters.

Por que a alternativa D parece tentadora, mas está errada: forward proxy intermedeia clientes, não cria túnel entre redes.

Por que a alternativa E parece tentadora, mas está errada: WAF é proteção web, não VPN.

Questão 9 - Gabarito: D

Por que a correta está correta: I e III estão corretas: VPN protege tráfego por túnel e pode permitir acesso remoto conforme política. II está errada porque VPN não substitui autorização e segmentação.

Por que a alternativa A parece tentadora, mas está errada: inclui a II, que exagera o alcance da VPN.

Por que a alternativa B parece tentadora, mas está errada: II está errada sozinha.

Por que a alternativa C parece tentadora, mas está errada: novamente inclui II e exclui III indevidamente.

Por que a alternativa E parece tentadora, mas está errada: III é correta, mas I também é.

Questão 10 - Gabarito: A

Por que a correta está correta: O sensor descrito analisa e alerta fora do caminho obrigatório. Esse é o comportamento típico de IDS.

Por que a alternativa B parece tentadora, mas está errada: IPS atua prevenindo/bloqueando inline.

Por que a alternativa C parece tentadora, mas está errada: firewall stateful controla tráfego; o enunciado fala em sensor passivo de alerta.

Por que a alternativa D parece tentadora, mas está errada: proxy reverso intermedeia requisições para servidores.

Por que a alternativa E parece tentadora, mas está errada: DMZ é zona de rede, não dispositivo sensor.

Questão 11 - Gabarito: C

Por que a correta está correta: IPS detecta e previne porque fica inline e pode descartar tráfego antes que alcance o alvo.

Por que a alternativa A parece tentadora, mas está errada: DNS recursivo resolve nomes, não bloqueia assinatura de exploração.

Por que a alternativa B parece tentadora, mas está errada: IDS passivo apenas alerta.

Por que a alternativa D parece tentadora, mas está errada: proxy direto representa clientes internos.

Por que a alternativa E parece tentadora, mas está errada: VLAN segmenta domínios de broadcast, não aplica assinatura de exploração inline.

Questão 12 - Gabarito: B

Por que a correta está correta: NIDS observa tráfego de rede; HIDS observa eventos de host; WAF inspeciona HTTP/HTTPS; VPN cria túnel protegido.

Por que a alternativa A parece tentadora, mas está errada: troca NIDS por HIDS nos dois primeiros itens.

Por que a alternativa C parece tentadora, mas está errada: coloca WAF como se fosse observador de host.

Por que a alternativa D parece tentadora, mas está errada: inverte as funções de WAF/VPN/NIDS.

Por que a alternativa E parece tentadora, mas está errada: atribui VPN à observação de rede e desloca os demais conceitos.

Questão 13 - Gabarito: E

Por que a correta está correta: Falso positivo é classificar tráfego legítimo como malicioso. Em IPS, isso é mais sensível porque há bloqueio automático.

Por que a alternativa A parece tentadora, mas está errada: falso negativo é ameaça real não detectada.

Por que a alternativa B parece tentadora, mas está errada: DNS poderia causar erro de resolução, mas o enunciado fala em classificação e bloqueio pelo IPS.

Por que a alternativa C parece tentadora, mas está errada: NAT não explica bloqueio por assinatura/regra.

Por que a alternativa D parece tentadora, mas está errada: roteamento assimétrico não é indicado e não é sempre ataque L7.

Questão 14 - Gabarito: D

Por que a correta está correta: DMZ é uma zona intermediária controlada para serviços expostos, evitando acesso direto da Internet à rede interna.

Por que a alternativa A parece tentadora, mas está errada: bancos críticos normalmente ficam na rede interna protegida.

Por que a alternativa B parece tentadora, mas está errada: DMZ não dispensa firewall; depende dele ou de controles equivalentes.

Por que a alternativa C parece tentadora, mas está errada: criptografia/túnel remete a VPN/IPsec, não DMZ.

Por que a alternativa E parece tentadora, mas está errada: DMZ não é protocolo de transporte.

Questão 15 - Gabarito: B

Por que a correta está correta: Proxy direto representa clientes internos e permite controle, autenticação e registro de navegação de saída.

Por que a alternativa A parece tentadora, mas está errada: proxy reverso representa servidores internos para clientes externos.

Por que a alternativa C parece tentadora, mas está errada: HIDS monitora host.

Por que a alternativa D parece tentadora, mas está errada: VPN site-to-site conecta redes por gateways.

Por que a alternativa E parece tentadora, mas está errada: WAF protege aplicação web exposta; não é política genérica de navegação interna.

Questão 16 - Gabarito: C

Por que a correta está correta: A política segmenta zonas e limita fluxos: Internet só chega ao proxy na DMZ; proxy só chega à API; banco não recebe acesso direto externo.

Por que a alternativa A parece tentadora, mas está errada: proxy não elimina autenticação/autorização da aplicação.

Por que a alternativa B parece tentadora, mas está errada: a política nega acesso direto ao banco.

Por que a alternativa D parece tentadora, mas está errada: porta 443 sugere HTTPS, mas firewall não substitui TLS por NAT.

Por que a alternativa E parece tentadora, mas está errada: DMZ não vira rede interna sem controle.

Questão 17 - Gabarito: A

Por que a correta está correta: I e III estão corretas. II está errada porque IDS detecta/alerta, enquanto IPS pode bloquear inline.

Por que a alternativa B parece tentadora, mas está errada: inclui a afirmativa II, que iguala IDS e IPS indevidamente.

Por que a alternativa C parece tentadora, mas está errada: ignora I e III corretas.

Por que a alternativa D parece tentadora, mas está errada: inclui II, que está errada.

Por que a alternativa E parece tentadora, mas está errada: III é correta, mas I também é.

Questão 18 - Gabarito: E

Por que a correta está correta: Para inspecionar HTTP dentro de HTTPS, o WAF ou componente de borda precisa ter visibilidade do tráfego de aplicação, com terminação TLS ou arranjo equivalente conforme a arquitetura.

Por que a alternativa A parece tentadora, mas está errada: hub repete sinais e não inspeciona HTTP.

Por que a alternativa B parece tentadora, mas está errada: ARP não encapsula parâmetros HTTP.

Por que a alternativa C parece tentadora, mas está errada: DHCP não dá visibilidade de camada de aplicação.

Por que a alternativa D parece tentadora, mas está errada: WAF não exige eliminar segurança; pode operar com TLS termination/recryptografia ou integração apropriada.

Questão 19 - Gabarito: D

Por que a correta está correta: A limitação do impacto decorre de segmentação por zonas e regras restritivas entre DMZ e rede interna.

Por que a alternativa A parece tentadora, mas está errada: trocar HTTP por UDP não tem relação com proteção do banco.

Por que a alternativa B parece tentadora, mas está errada: eliminar logs piora segurança.

Por que a alternativa C parece tentadora, mas está errada: hub não isola; repete tráfego.

Por que a alternativa E parece tentadora, mas está errada: DNS reverso não impede conexão TCP por si só.

Questão 20 - Gabarito: B

Por que a correta está correta: Firewall L3/L4 filtra por IP, protocolo e porta, mas não entende plenamente a regra de negócio da API; esse é justamente o limite clássico.

Por que a alternativa A parece tentadora, mas está errada: VPN não dispensa identidade e autorização.

Por que a alternativa C parece tentadora, mas está errada: IDS não bloqueia por definição; IPS bloqueia.

Por que a alternativa D parece tentadora, mas está errada: WAF é focado em web, não em ARP/ICMP/storage em bloco.

Por que a alternativa E parece tentadora, mas está errada: DMZ requer segmentação, não a elimina.

17. Checklist final de domínio

- Consigo diferenciar firewall, proxy, VPN, DMZ, IDS e IPS pelo verbo do enunciado.
- Sei explicar firewall stateless e stateful sem confundir com WAF ou NGFW.
- Sei que WAF é focado em HTTP/HTTPS e ataques de aplicação web.
- Sei diferenciar proxy direto de proxy reverso.
- Sei diferenciar VPN site-to-site de client-to-site.
- Sei que VPN cria túnel seguro, mas não substitui autorização, segmentação e monitoramento.
- Sei posicionar DMZ entre Internet e rede interna, com regras restritivas.
- Sei que IDS detecta/alerta e IPS previne/bloqueia inline.
- Sei diferenciar NIDS, HIDS, detecção por assinatura e por anomalia.
- Sei identificar falso positivo e falso negativo em cenários de IDS/IPS.

18. Fontes técnicas consultadas

Esta aula é autoral e foi construída para o edital TJSC 2026 - Analista de Sistemas, com calibração por referências oficiais/técnicas e por padrão de questões FGV de TI observado em provas recentes correlatas. As questões são inéditas e não reproduzem questões reais.

Fonte	Uso na aula
Edital TJSC 2026 - FGV	Recorte do cargo, disciplina e tópicos de Infraestrutura de TI e Computação em Nuvem.
Manual Mestre de Calibração FGV para Aulas e Questões	Régua editorial: teoria progressiva, questões fortes, gabarito orgânico e acessibilidade.
NIST SP 800-41 Rev. 1 - Guidelines on Firewalls and Firewall Policy	Definições e boas práticas de firewall e política de firewall.
NIST SP 800-94 - Guide to Intrusion Detection and Prevention Systems	IDS/IPS, NIDS, HIDS, detecção, prevenção e manutenção.
NIST SP 800-77 Rev. 1 - Guide to IPsec VPNs	VPN IPsec, segurança em camada de rede, IKE e cenários de implementação.
NIST SP 800-113 - Guide to SSL VPNs	VPN SSL/TLS, acesso remoto e comparação com IPsec.

Fonte	Uso na aula
RFC 4949 - Internet Security Glossary	Terminologia de segurança da informação e redes.
Cloudflare Learning Center - Reverse Proxy	Apoio didático para a distinção entre proxy e proxy reverso.

Fim da Aula 5.